

Bezpieczeństwo systemów informacyjnych

# Bezpieczeństwo systemów informacyjnych

Elektronika i Telekomunikacja 2 st., sem. 2

1

Bezpieczeństwo systemów informacyjnych

## Plan wykładu

- ❑ Podstawowe informacje o bezpieczeństwie systemów sieciowych
- ❑ Rodzaje zagrożeń cybernetycznych w systemach teleinformatycznych
  - ✓ zagrożenia dla sieci (np. *sniffing*, *spoofing*, *DoS*);
  - ✓ zagrożenia dla aplikacji (np. błędy przepełnienia bufora, *SQL Injection*, *Cross-Site Scripting*, modyfikacja ukrytych pól w formularzach WWW);
  - ✓ zagrożenia dla użytkowników (*social engineering*, *phishing*).
    - Kompleksowa polityka bezpieczeństwa systemów teleinformatycznych
    - Szkolenia użytkowników

2

Bezpieczeństwo systemów informacyjnych

## Plan wykładu

- ❑ Środki ochrony przed poszczególnymi rodzajami zagrożeń:
  - ✓ Kryptograficzna ochrona informacji:
    - ❖ szyfrowanie danych, uwierzytelnianie wiadomości, podpisy cyfrowe
  - ✓ Systemy uwierzytelniania i autoryzacji użytkowników
  - ✓ Zabezpieczenia sieci Wi-Fi (WPA) oraz komórkowych (GSM/UMTS/LTE ...)
  - ✓ Wybrane technologie zabezpieczeń sieciowych:
    - ❖ SSL/TLS, 802.1x, VPN, IPsec, SSH
  - ✓ Środki ochrony sieciowej:
    - ❖ zapory sieciowe (*firewalls*), systemy wykrywania włamań (IDS), systemy fałszywych celów ataku (*honeypots*)
  - ✓ Zagadnienia zabezpieczeń w w systemach webowych i IoT
  - ✓ Wybrane technologie zapewnienia wysokiej dostępności i niezawodności systemów

3

Bezpieczeństwo systemów informacyjnych

## Efekty uczenia się

- ❑ Student, który zaliczył przedmiot:
  - ✓ opisuje działanie i właściwości określonych algorytmów kryptograficznych oraz ich aplikacji w systemach i technologiach zapewnienia bezpieczeństwa systemów informacyjnych.
  - ✓ opisuje działanie wybranych praktycznych rozwiązań stosowanych do zapewnienia bezpieczeństwa systemów informacyjnych
  - ✓ charakteryzuje zagrożenia specyficzne dla określonych rodzajów aplikacji
  - ✓ wyjaśnia zastosowanie określonych standardów i rekomendacji związanych z technicznymi i organizacyjnymi aspektami zapewnienia bezpieczeństwa systemów informacyjnych

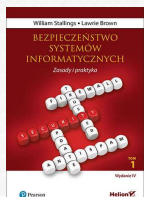
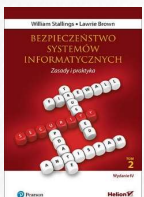
4

Bezpieczeństwo systemów informacyjnych

## Literatura

- ❑ William Stallings, Lawrie Brown:
 

*Bezpieczeństwo systemów informatycznych. Zasady i praktyka.*  
Wydanie IV, tom 1 i 2, Helion, Gliwice 2019.

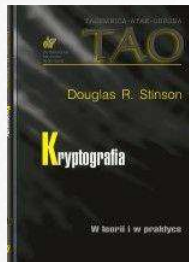
5

Bezpieczeństwo systemów informacyjnych

## Literatura c.d.

- ❑ Stinson Douglas R.
 

*Kryptografia. W teorii i praktyce.*  
WNT, Warszawa 2005



6

**Literatura c.d.**

Bezpieczeństwo systemów informacyjnych

□ Krishna Sankar, Sri Sundaralingam, Andrew Balinsky, Darrin Miller  
 Bezpieczeństwo sieci bezprzewodowych. *Ochrona sieci 802.11. Porady eksperta.*  
 MIKOM, Warszawa 2005



7

**Literatura**

Bezpieczeństwo systemów informacyjnych

□ Andrzej Białas:  
*Bezpieczeństwo informacji i usług w nowoczesnej instytucji i firmie.*  
 Wydanie II, WNT, Warszawa 2007.



8

**Literatura c.d.**

Bezpieczeństwo systemów informacyjnych

□ *Ocena bezpieczeństwa sieciowego.*  
 Promise (Microsoft Press), Warszawa 2005

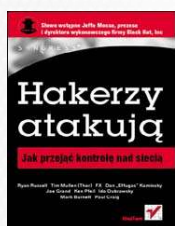


9

**Literatura c.d.**

Bezpieczeństwo systemów informacyjnych

□ Ryan Russell, Tim Mullen (Thor), FX, Dan "Effugas" Kaminsky, Joe Grand, Ken Pfeil, Ido Durbrowsky, Mark Burnett, Paul Craig  
*Hakerzy atakują. Jak przejąć kontrolę nad siecią.*  
 Helion, Gliwice 2004



10

**Literatura c.d.**

Bezpieczeństwo systemów informacyjnych

- Witryny internetowe:
  - <http://niebezpiecznik.pl>
  - <http://zaufanatrzeciastrona.pl>
  - <http://sekurak.pl>
  - <http://www.cert.pl>

11

Bezpieczeństwo systemów informacyjnych

**Podstawowe zagadnienia związane z bezpieczeństwem systemów sieciowych**

12



## Bezpieczeństwo systemów informacyjnych

### Wstęp

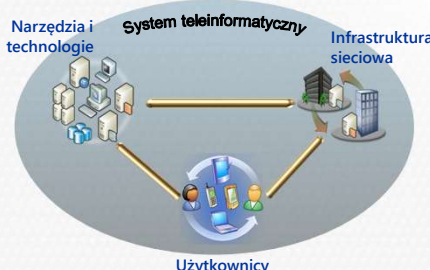
- ❑ Bezpieczeństwo: stan braku zagrożenia
- ❑ Bezpieczeństwo informacji:
  - ✓ **Poufność**: tylko upoważnione osoby mają dostęp do informacji
  - ✓ **Integralność**: zapewnienie poprawności informacji i braku możliwości dokonywania nieautoryzowanych zmian
  - ✓ **Dostępność**: dane muszą być swobodnie dostępne dla autoryzowanych użytkowników i operacji
- ❑ Procedury bezpieczeństwa muszą być uwzględnione w każdym miejscu związanym z przechowywaniem, przesyłaniem, przetwarzaniem lub użytkowaniem informacji.

13

## Bezpieczeństwo systemów informacyjnych

### Wstęp

- ❑ Bezpieczeństwo informacji może być uzyskane jedynie w ciągłym procesie obejmującym trzy podstawowe elementy:
  - ✓ **Produkty** (bezpieczeństwo logiczne i fizyczne)
  - ✓ **Ludzi**
  - ✓ **Procedury**



14

## Bezpieczeństwo systemów informacyjnych

### Wstęp

- ❑ Bezpieczeństwo fizyczne urządzeń jest równie istotne jak zabezpieczenia od strony logicznej

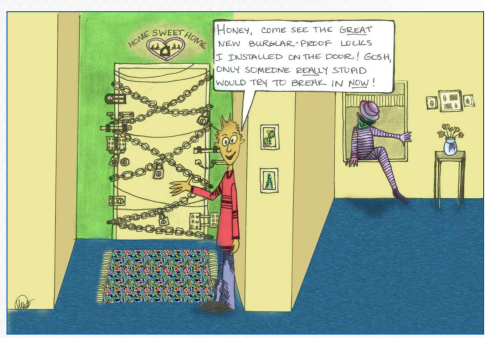


15

## Bezpieczeństwo systemów informacyjnych

### Wstęp

- ❑ Zasada najsłabszego ogniwa



16

## Bezpieczeństwo systemów informacyjnych

### Wstęp

- ❑ Zabezpieczanie sieci stanowi duże wyzwanie:
  - ✓ Powszechnie stosowane protokoły sieciowe (ARP, IP, UDP, TCP, DNS) są dobre pod względem technicznym, ale były projektowane bez uwzględnienia zagadnień bezpieczeństwa
  - ✓ Dlatego sieci muszą być uzupełniane o dodatkowe rozwiązania takie jak firewalle oraz systemy uwierzytelniania i autoryzacji

17

## Bezpieczeństwo systemów informacyjnych

### Wstęp

**Firewall zazwyczaj nie wystarczy!**



18

## Wstęp

Bezpieczeństwo systemów informacyjnych

- Bezpieczeństwo wielopoziomowe
  - ✓ Rozbicie procedur zabezpieczających na osobne warstwy
  - ✓ Zwiększa szansę wykrycia ataku
  - ✓ Zmniejsza możliwość skutecznego włamania

19

## Wstęp – bezpieczeństwo wielopoziomowe

Bezpieczeństwo systemów informacyjnych

**Cisco Self-Defending Network: A Strategic Systems Approach to Information Security**

The diagram illustrates the Cisco Self-Defending Network architecture. It features a central stack of security layers: System Management, Application Security, Content Security, Network Security, Endpoint Security, and Self-Defending Network. Below this stack, a box labeled 'Best of Breed Security in a Systems Approach' points to a 'Components of the Cisco Self-Defending Network' section. This section is divided into three main areas: CONTROL (TRUST AND IDENTITY), PRIVACY (SECURE CONNECTIVITY), and PROTECTION (THREAT DEFENSE). Each area has a brief description of its function. At the bottom, a yellow banner indicates 'Management, Monitoring & Analysis'.

20

## Wstęp – bezpieczeństwo wielopoziomowe

Bezpieczeństwo systemów informacyjnych

**Propozycja Microsoftu: Defense in Depth**

The diagram shows the Microsoft Defense in Depth model. It consists of a central stack of layers: Dane, Aplikacja, Host, Sieć wewnętrzna, Brzeg sieci, and Bezpieczeństwo fizyczne. To the right of each layer, specific security measures are listed: Listy kontroli dostępu, szyfrowanie; Uszczelnianie aplikacji, ochrona AV; Uszczelnianie OS, zarządzanie poprawkami, uwierzytelnianie, Host IDS; Segmentowanie, IPSec, Sieciowe IDS; Firewalls, VPN quarantine; and Zamki, ochrona, śledzenie położenia. At the bottom, 'Zasady, procedury i świadomość' is linked to 'Edukacja użytkowników'.

21

## Wstęp – kilka faktów związanych z bezpieczeństwem

Bezpieczeństwo systemów informacyjnych

**Dobre fakty**

- Generalnie wzrasta świadomość istotności zagadnień bezpieczeństwa
- Stare, powszechnie znane metody ataków zazwyczaj nie działają we współczesnych systemach
  - ✓ Ataki sieciowe
  - ✓ Podstawowe sztuczki inżynierii społecznej

22

## Wstęp – kilka faktów związanych z bezpieczeństwem

Bezpieczeństwo systemów informacyjnych

**Złe fakty**

- Pojawienie się nowych rodzajów ataków
  - ✓ Ataki aplikacyjne
  - ✓ Połączenie spamu z wirusami i innym złośliwym oprogramowaniem
  - ✓ Rozwój i ulepszenie ataków DDoS
  - ✓ Spyware, Phishing, Ransomware
  - ✓ Attack-as-a-Service (AAAS) np. Ransomware-as-a-Service (RaaS)

23

## Wstęp – kilka faktów związanych z bezpieczeństwem

Bezpieczeństwo systemów informacyjnych

**Złe fakty**

- Obserwowany jest ciągły wzrost szybkości ataków wykorzystujących ujawnione słabe punkty oprogramowania stacji roboczych i urządzeń sieciowych
- Coraz częstsze pojawianie się ataków typu zero-day (Pegasus!)
  - ✓ Ataki zero-day wykorzystują nieznane wcześniej słabe punkty oprogramowania

26

## Wstęp – kilka faktów związanych z bezpieczeństwem

Bezpieczeństwo systemów informacyjnych

### Złe fakty

- ❑ Większość komputerów jest podłączona do Internetu
  - ✓ Daje to możliwość szybkiego rozprzestrzeniania się zagrożeń oraz przeprowadzania ataków rozproszonych

27

27

## Wstęp – kilka faktów związanych z bezpieczeństwem

Bezpieczeństwo systemów informacyjnych

### Złe fakty

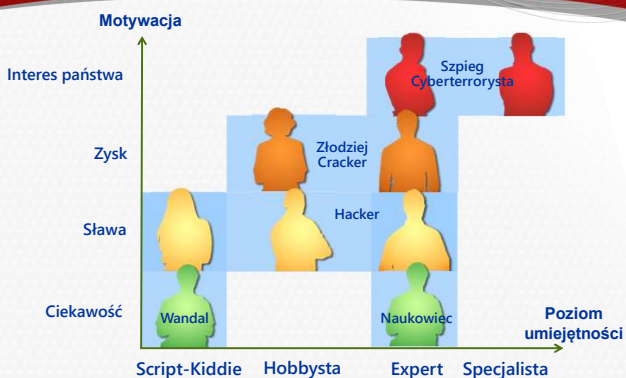
- ❑ Coraz wyższe wyrażenie ataków
  - ✓ Ataki stają się coraz bardziej skomplikowane, co wymusza stosowanie skomplikowanych metod obrony
  - ✓ Narzędzia do przeprowadzania ataków mają często możliwość zmiany ich zachowania, przez co każdy atak może wyglądać nieco inaczej
  - ✓ Ataki zorientowane aplikacyjnie używają zazwyczaj standardowych portów TCP takich jak 80, które są zwykle otwarte na firewallach
  - ✓ Powszechna dostępność odpowiednich narzędzi (także typu AACS) stwarza możliwość przeprowadzania bardzo wyrafinowanych technicznie ataków przez użytkowników bez specjalistycznego przygotowania

29

29

## Wstęp – profile sieciowych włamywaczy

Bezpieczeństwo systemów informacyjnych



30

30

## Źródła zagrożeń dla systemów informacyjnych

Bezpieczeństwo systemów informacyjnych

31

## Możliwe cele ataków

Bezpieczeństwo systemów informacyjnych

### ❑ Możliwe cele ataków i rodzaje zagrożeń:

- Stacje sieciowe (serwery, stacje robocze, urządzenia składowania danych, czujniki IoT)
  - ✓ nieupoważniony dostęp do danych (np. poprzez atak off-line)
  - ✓ nieupoważniona modyfikacja danych (w tym zaszyfrowanie – ransomware)
- Infrastruktura sieciowa (routery, przełączniki, bramki IoT itd.)
  - ✓ Podłuch przesyłanych danych (sniffing) bezpośrednio lub poprzez tzw. emisję ujawniającą (side-channel attack)
  - ✓ Falszowanie pakietów danych (spoofing)
- Aplikacje (systemy operacyjne, programy użytkowe, aplikacje webowe)
  - ✓ Podstawienie i wykonanie własnego kodu np. poprzez wykorzystanie tzw. przepełnienia bufora (Buffer overflow)
  - ✓ Wstrzykiwanie komend SQL (SQL Injection)
  - ✓ Cross Site Scripting (XSS) – wykradanie danych zapisanych w ciasteczkach (cookies) np. w celu przejęcia tokena uwierzytelnionego użytkownika
  - ✓ Cross-site request forgery (CSRF, XSRF)
  - ✓ Ataki odmowy usługi (DoS, DDoS – Distributed Denial of Service)
- Użytkownicy (np. jako „nośniki” hasel)
  - ✓ Phishing

32

32